Final Cyber Security Assessment Summary

The workflow automation platform has undergone a comprehensive security hardening process. The application mitigates critical risks associated with handling PII by implementing strict data minimization protocols, Microsoft Entra ID authentication, and encrypted cloud infrastructure. All identified high-severity vulnerabilities have been patched, and the system is assessed as secure and ready for production deployment.

Cyber Tasks and Feature

1. Data Minimization and PII Protection
   - Configured the application to process PII (like SSNs and bank routing numbers) in-memory during PDF generation. These values are omitted from the PostgreSQL database models to prevent persistence.
2. Credential and Secret Management
   - Removed all API keys, database URLs, and secrets from the source code and cloudbuild.yaml pipelines.
   - Implemented Google Secret Manager to dynamically inject these credentials only at runtime in the production Google Cloud environment.
3. Cloud Log and POST Request Security
   - Applied Data Filter classes to the Django configuration to make sure that crashed requests or stack traces do not print sensitive payload data into the Google Cloud Logs Explorer or that sensitive info does not leak into POST requests.
4. Authentication and Access Control
   - Replaced the unsecured temporary login with Microsoft Entra ID OAuth using django-allauth
   - Configured the Azure App Registration to enforce Single-Tenant access, restricting the admin dashboard to only Insighters Tenants.
   - Implemented a secure Temporary Client Access system utilizing hashed passwords, strict expiration timestamps, and a one-time use burn flag to permanently invalidate credentials immediately after form submission.
   - Enforced strict administrator session security, including a 1-hour hard expiration, idle timeout resets on every request, and automatic session destruction upon browser closure.
5. Secure Data Transmission and Web Security

- Enforced production SSL/TLS settings, including secure cookies and strict CSRF trusted origins for the public Cloud Run deployment URL.
- Configured Cloud SQL database to only allow connections via SSL
- Automatically Provisioned HTTPS endpoint via Cloud Run (automatic TLS/SSL certificate issuance and renewal and redirection of HTTP requests to HTTPS)
- Implemented anti-clickjacking defenses to block the application forms and admin dashboard from being maliciously embedded inside hidden external iframes.

6. Container and Infrastructure Security
   - Configured Docker to run in rootless mode, making sure containers execute without root privileges.

Cyber Tasks Remaining

1. Client Secret Rotation Schedule
   - The Microsoft Entra ID ENTRA_CLIENT_SECRET is currently set to expire in 180 days from provisioning (October 1, 2026). A calendar reminder must be established for the IT team to rotate this credential before expiration to prevent a loss of SSO access.

Cyber Checklist

To maintain the security integrity of the platform, the IT administrative team must periodically review the following items:

- **[ ] Secret & Token Rotation:** Make sure the Microsoft Entra ID Client Secret, Monday.com API tokens, and Django Secret Key stored in Google Secret Manager are rotated annually or bi-annually.

- **[ ] Cloud Log Monitoring:** Monthly review of the Google Cloud Logs Explorer to check for unusual spikes in failed login attempts, 500 server errors, or unauthorized access attempts.

- **[ ] Dependency & Vulnerability Patching:** Bi-annually check the Python/Django environment and the Docker base image for newly published Common Vulnerabilities and Exposures (CVEs) and update packages accordingly.

- **[ ] Infrastructure Review:** Annually review Google Cloud IAM policies to ensure the principle of least privilege is maintained for the service accounts running the Cloud Run deployment and Cloud SQL database.